

Data Protection and Privacy Policy

Owner: Privacy | Version: 3.0-rag | Effective date: 2026-04-20

Document type	Synthetic policy manual
Use case	RAG training, retrieval benchmarking, QA evaluation
Chunking guidance	Use one chunk per section and preserve section IDs

1. Purpose and Scope

Data Protection and Privacy Policy describes the formal policy requirements and operating procedures used by Northstar Analytics Ltd.. It is written as a synthetic but realistic document for training retrieval, summarization, and question-answering systems.

This document applies to all employees, interns, temporary workers, and approved contractors unless a section explicitly states otherwise.

Managers are responsible for enforcing this policy consistently and for escalating unusual cases to the document owner.

2. Roles and Responsibilities

Employees must read, understand, and follow the policy requirements relevant to their role.

Managers must document exceptions in writing and retain approvals in the designated system of record.

The document owner reviews this policy at least annually and whenever business, legal, or technical requirements materially change.

3. Personal Data Categories

The section on personal data categories defines the standard rule, the approval path, and the records that must be retained.

Requests related to personal data categories should be submitted through the official workflow rather than handled informally through chat or email alone.

When a manager grants an exception for personal data categories, the exception must include the reason, the duration, and any compensating controls.

Records related to personal data categories must be stored in the designated repository with a clear owner and retention period.

Metrics related to personal data categories should be reviewed periodically to identify recurring issues and opportunities for improvement.

4. Lawful Basis

The section on lawful basis defines the standard rule, the approval path, and the records that must be retained.

Requests related to lawful basis should be submitted through the official workflow rather than handled informally through chat or email alone.

When a manager grants an exception for lawful basis, the exception must include the reason, the duration, and any compensating controls.

Records related to lawful basis must be stored in the designated repository with a clear owner and retention period.

Metrics related to lawful basis should be reviewed periodically to identify recurring issues and opportunities for improvement.

5. Retention

The section on retention defines the standard rule, the approval path, and the records that must be retained.

Requests related to retention should be submitted through the official workflow rather than handled informally through chat or email alone.

When a manager grants an exception for retention, the exception must include the reason, the duration, and any compensating controls.

Routine HR and operational records are generally retained for 7 years unless a longer period is required by contract, litigation hold, or law.

Deletion schedules must be paused when a legal hold notice is issued.

6. Data Subject Requests

The section on data subject requests defines the standard rule, the approval path, and the records that must be retained.

Requests related to data subject requests should be submitted through the official workflow rather than handled informally through chat or email alone.

When a manager grants an exception for data subject requests, the exception must include the reason, the duration, and any compensating controls.

Privacy requests should be acknowledged within 5 business days and tracked to closure in the privacy request log.

Identity must be reasonably verified before personal data is disclosed or erased.

7. Breach Response

The section on breach response defines the standard rule, the approval path, and the records that must be retained.

Requests related to breach response should be submitted through the official workflow rather than handled informally through chat or email alone.

When a manager grants an exception for breach response, the exception must include the reason, the duration, and any compensating controls.

Potential personal data breaches must be escalated to Privacy and Security immediately for assessment.

Internal notification should occur without undue delay and target an initial assessment window of 72 hours.

8. Exceptions and Escalations

Exceptions must be rare, time-bound, and approved by the designated authority named in the relevant section.

All exceptions must be logged with the approver, rationale, expiration date, and any required follow-up actions.

9. Document Control

Document owner: Data Protection and Privacy Policy owner

Version: 3.0-rag

Effective date: 2026-04-20

Review frequency: annual or upon material change